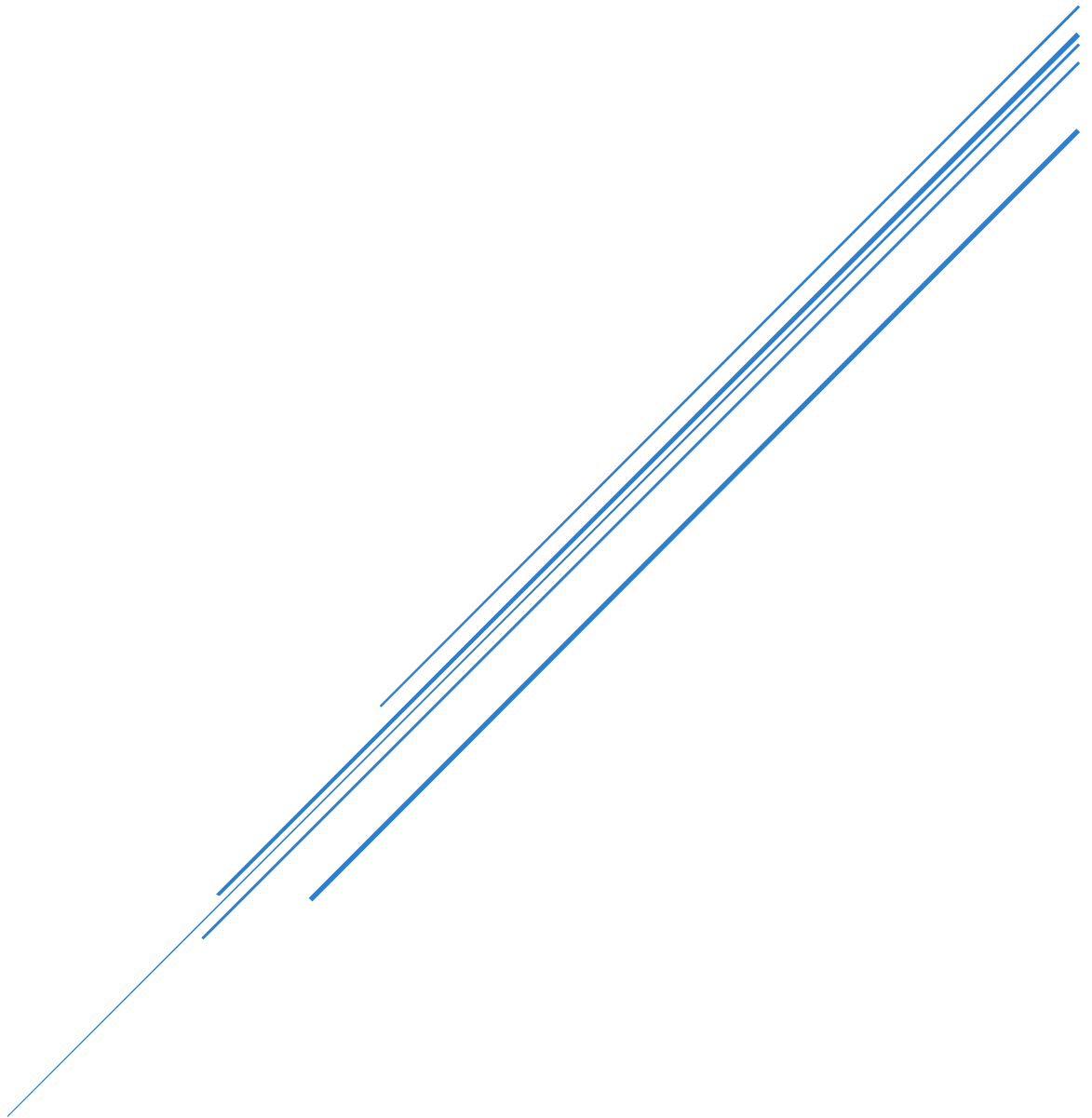


NETWORK REDESIGN

Version 1



Network security

Table of Contents

Introduction.....	1
Physical Security Weaknesses	1
Network Security Weaknesses	2
Safeguards and Improvements to Site Arrangements	3
Network Redesign.....	4
References	7

Introduction

This report assesses the physical and network security of a two-building law firm in western Edinburgh. Its rushed setup created a flat, weakly controlled network, prompting safeguards and a secure redesign after a recent intrusion.

Physical Security Weaknesses

Physical security forms the first line of defence in any security model (Fausto *et al.*, 2021). In this law firm, several significant weaknesses were identified:

- **Inter-building link:** The shielded 1Gb copper cable is suspended over a busy public street, making it physically accessible and vulnerable to tampering, cutting, or interception without conduit protection.
- **Perimeter and access:** Neither building shows barriers, CCTV, visitor logs or controlled entry. The main building contains an unused shop front with a public-facing window used as a fire exit, creating an additional uncontrolled entry point from a commercial street.
- **Infrastructure exposure:** Wiring Closet 1 is accessible within the lawyers' office and Wiring Closet 2 sits beside the public reception seating area. In the smaller building, the server room and wiring closet are adjacent to reception. Network switches are placed under desks, behind reception desks, on filing cabinets and on a wall in a seating area. Critical infrastructure in public-facing or general working areas can be tampered with, stolen, or used to connect rogue devices.
- **Environmental hazards:** There is no evidence of locked racks, Uninterruptible Power Supply (UPS), cooling, cable containment or fire suppression exist at either site. The unused server room presents an insider threat risk as an unmonitored space. As the network appears to rely on single connections between key devices, one damaged cable or switch could interrupt both business operations and access to legal data.

Network Security Weaknesses

The current network diagram shows an architecture unsuitable for confidential legal data. The key weaknesses are:

- **Flat network:** Both sites share a single subnet (195.2.2.0/24) with no Virtual Local Area Network (VLAN) segmentation. A single compromised device allows unrestricted lateral movement to all others, including document and backup servers (Kotha, 2020).
- **Internet-facing server exposure:** The web server connects directly to the internet through the VDSL router with no enterprise firewall or Demilitarised Zone (DMZ). Without a DMZ, a compromised web server could have unrestricted access to internal systems, which is a fundamental network security failure (Maurya *et al.*, 2026).
- **Insufficient firewalling, Access Control Lists (ACLs) and traffic control:** There is no clear evidence of stateful firewalls, internal ACLs or controlled routing between departments. Without these controls, traffic may flow too freely between user areas, servers and Internet services. Packet filters and ACLs are used to control permitted and denied traffic, while stateful firewalls reduce exposure by allowing valid return traffic dynamically rather than leaving permanent openings (Parthasarathy *et al.*, 2021).
- **Unsecured inter-building link:** The aerial copper cable carries inter-site traffic with no encryption. Without a Virtual Private Network (VPN), this traffic is readable to anyone intercepting the physical link, creating confidentiality and integrity risks for legal data (Ogudo, 2019).
- **No Authentication, Authorisation and Accounting (AAA) or monitoring:** The network shows no RADIUS, TACACS+, 802.1X, IDS/IPS or centralised logging. Any device can connect without authentication, increasing the risk of rogue devices and undetected intrusions.
- **Consumer-grade equipment:** The Linksys N300 mixes staff and personal devices on one connection. As a home router, it is unsuitable for a law firm requiring VLAN separation, centralised authentication, managed logging and enterprise firewall control (Linksys, 2014).

- **Backup exposure:** Mirror servers share the same flat network as users and internet-facing services, meaning ransomware could destroy both live data and backups simultaneously.
- **Security offices unconnected:** Security staff have no access to monitoring tools or alerts, eliminating real-time incident detection capability entirely.

Safeguards and Improvements to Site Arrangements

As the organisation handles confidential legal data, physical safeguards must protect systems from following improvements:

- **Perimeter controls:** Both sites should implement CCTV, external lighting, barrier-controlled car park entry and visitor management at reception. Visitors should sign in, provide identification and be escorted. Staff-only areas should use electronic card access, while fire exits must remain legally compliant but alarmed against unauthorised external entry (NPSA, 2026). The unused shop front should have reinforced glass, alarm monitoring and no external handle fitted.
- **Infrastructure protection:** Wiring Closet 1 should be partitioned using a stud wall with a solid-core locked door. Wiring Closet 2 should be enclosed in a locked steel cabinet bolted to the wall. Switches currently placed under desks, behind reception or in filing cabinets, should be moved into locked racks or secure communications cabinets. The unused server room should be locked and alarmed to prevent covert use. Both server rooms should have electronic card access restricted to authorised IT staff only, following Zero Trust principles that require access to be explicitly verified rather than automatically trusted (Gambo and Almulhem, 2025).
- **Secure cabling and operational protection:** The exposed inter-building cable over the public street should be replaced with a protected underground duct, leased fibre link or secure cable route. Critical equipment should be protected with locked racks and fire/water protection. UPS, cooling, fire suppression and cable containment should be installed at both server rooms. The security offices should be connected to monitoring systems so staff can view alerts and respond quickly across both sites.

Network Redesign

Figure 1 shows the proposed secure redesign, replacing the original flat network with firewall zoning, DMZ isolation, VLAN segmentation, AAA authentication, IDS/IPS monitoring and an encrypted site-to-site VPN.

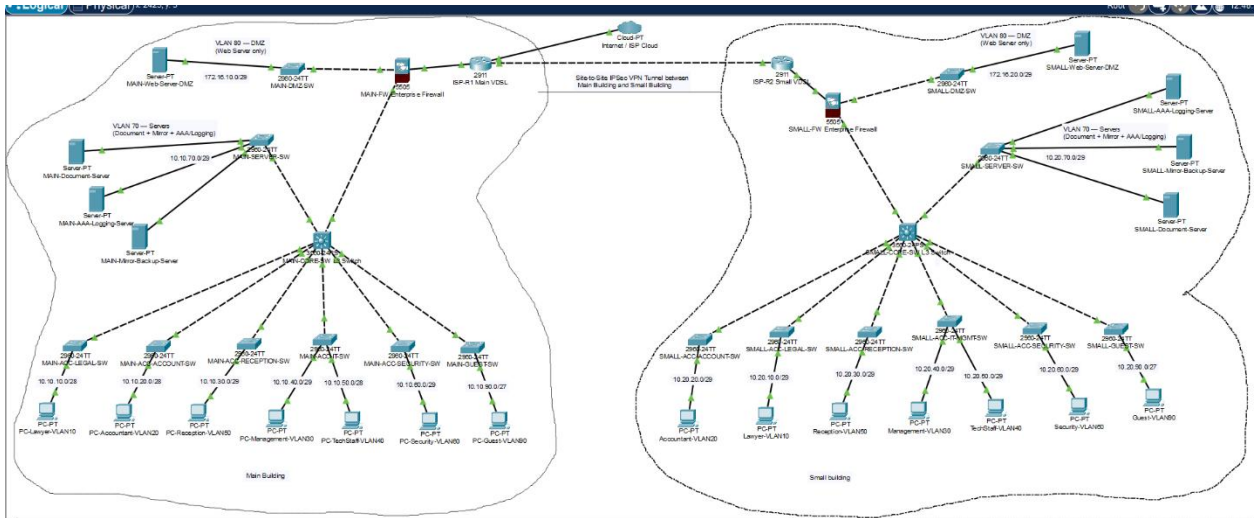


Figure 1: Proposed secure network redesign for the main and smaller building

As shown in Figure 1, all recommendations apply defence-in-depth, requiring multiple overlapping security layers so no single failure causes total compromise (Jangam and Pedda Mun-tala, 2024).

- **Enterprise Firewall and DMZ:** At both sites, an ASA firewall should sit between the VDSL router and internal network, with the public web server isolated in a DMZ (Mau-rya *et al.*, 2026). The redesign uses a Cisco ASA 5505 as a Packet Tracer-compatible firewall to demonstrate outside, DMZ and inside zones. ASA was preferred to a Cisco IOS zone-based firewall because it separates firewall, VPN and routing functions more clearly, reducing misconfiguration risk (Algabri, Rashid and Al-junid, 2025). The web server must not initiate connections toward the inside network under any circumstances, directly remediating the original breach vector.
- **VLAN segmentation and ACLs:** The flat network should be replaced with segmented VLANs controlled by a Layer 3 core switch. In the redesign diagram, a Cisco 3560 is

used as the Packet Tracer-compatible Layer 3 core switch to demonstrate inter-VLAN routing and ACL enforcement. VLAN 10 (Lawyers) and VLAN 20 (Accountants) are separated as distinct confidentiality domains, while VLAN 30 (Management) isolates administrative traffic from general user traffic. VLAN 40 (Tech Staff) allows controlled elevated access, and VLAN 50 (Reception) is heavily restricted because it is closest to public visitors. VLAN 60 (Security) provides isolated access to CCTV and monitoring systems. VLAN 70 (Servers) contains document, mirror and AAA servers, with ACLs permitting only authorised application traffic. VLAN 80 (DMZ) contains the public-facing web server and should be controlled by the ASA firewall, not treated as part of the trusted internal network. VLAN 90 (Guest) has internet access only. This segmentation limits lateral movement, so one compromised device cannot freely access all departments and servers (Kotha, 2020).

- **Replacement of switches:** The existing legacy access switches should be replaced with managed access switches supporting VLAN trunking, port security and 802.1X authentication. In the redesign, Cisco 2960 switches are used as Packet Tracer-compatible access switches to demonstrate these controls. They connect end-user devices, while trunk links carry VLAN traffic to the Layer 3 core switch for routing and ACL enforcement, creating a more secure and manageable access layer (Cisco, 2006, 2007).
- **AAA and 802.1X Authentication:** A RADIUS server should be placed on the server VLAN to provide centralised AAA authentication for 802.1X network access (Akshay *et al.*, 2025). RADIUS is preferred over TACACS+ because it is better suited to end-user/device authentication, while TACACS+ is mainly used for administrative CLI access (Ikhsan *et al.*, 2024). Managed access switches forward authentication requests to RADIUS before granting access. Approved devices enter the correct VLAN, while failed or unknown devices are placed in a quarantine VLAN. Unused ports should be disabled and assigned to a blackhole VLAN to prevent rogue connections (Akshay *et al.*, 2025).
- **Encrypted inter-building link:** Inter-site traffic should be protected by site-to-site IP-Sec VPN tunnel (Ogudo, 2019). IPSec was selected over GRE, which provides encapsulation but no encryption, and over SSL VPN, which is designed for individual remote

access rather than permanent site-to-site links. IKE Phase 1 establishes a mutually authenticated channel; IKE Phase 2 encrypts all traffic using AES-256 (Ogudo, 2019).

- **IDS/IPS and monitoring:** IDS/IPS should be deployed inline at both sites with all devices logging to a centralised syslog/SIEM server (Gupta, Jindal and Bedi, 2023). The original breach was discovered only by manual intervention; automated detection would have identified it far earlier.
- **Security offices connected:** Both security offices should be connected to a dedicated VLAN providing access to monitoring dashboards, CCTV systems, and access control logs, restoring real-time incident detection capability that is currently entirely absent from both sites.

References

- Akshay, C. *et al.* (2025) 'IEEE 802.1X Authentication and Security Mechanisms in Modern Networks', *Conference Proceedings - 2025 4th International Conference on Advances in Computing, Communication, Embedded and Secure Systems, ACCESS*, Ernakulam, India, 11-13 June. IEEE, pp. 679–686. Available at: <https://doi.org/10.1109/ACCESS65134.2025.11135604>.
- Algabri, M., Rashid, J. and Al-junid, E. (2025) 'EASD Exploiting ASDM Vulnerabilities and Proactive Defense Strategies Against Sophisticated Malware in Cisco ASA Firewalls Security', *Sana'a University Journal of Applied Sciences and Technology*, 3(4), pp. 933–940. Available at: <https://doi.org/10.59628/JAST.V3I4.1866>.
- Cisco (2006) *Configuring Layer 2 EtherChannel and Trunking Between 2900XL/3500XL/2950 Series Switches and Catalyst Switches That Run Cisco IOS Software - Cisco*. Available at: <https://www.cisco.com/c/en/us/support/docs/lan-switching/etherchannel/22422-144.html?> (Accessed: 10 May 2026).
- Cisco (2007) 'Catalyst 2960 Switch Command Reference'. Available at: <http://www.cisco.com> (Accessed: 10 May 2026).
- Fausto, A. *et al.* (2021) 'Toward the Integration of Cyber and Physical Security Monitoring Systems for Critical Infrastructures', *Sensors 2021, Vol. 21, Page 6970*, 21(21), p. 6970. Available at: <https://doi.org/10.3390/S21216970>.
- Gambo, M.L. and Almulhem, A. (2025) 'Zero Trust Architecture: A Systematic Literature Review', *Journal of Network and Systems Management 2025 34:1*, 34(1), pp. 25-. Available at: <https://doi.org/10.1007/S10922-025-09998-X>.
- Gupta, N., Jindal, V. and Bedi, P. (2023) 'A Survey on Intrusion Detection and Prevention Systems', *SN Computer Science 2023 4:5*, 4(5), pp. 439-. Available at: <https://doi.org/10.1007/S42979-023-01926-7>.
- Ikhsan, N. *et al.* (2024) 'Design and Build AAA Server using Free Radius Study Case Network Security Management at PT. XYZ', *2023 IEEE 9th International Conference on Computing, Engineering and Design, ICCED 2023*, Kuala Lumpur, Malaysia, 07-08 November 2023. IEEE. Available at: <https://doi.org/10.1109/ICCED60214.2023.10425645>.

Kumar Jangam, S. and Sarathi Reddy Pedda Muntala, P. (2024) ‘Comprehensive Defense-in-Depth Strategy for Enterprise Application Security’, *Golden Sun-Rise International Journal of Multidisciplinary on Science and Management*, 1(3), pp. 62–75. Available at: <https://doi.org/10.71141/30485037/V1I3P106>.

Maurya, V.K. *et al.* (2026) ‘NetFlow based Multi Layer Firewall Effectiveness and Validation Framework’, *2025 2nd International Conference on Pioneering Developments in Computer Science and Digital Technologies, IC2SDT 2025 – Proceedings*, Delhi, India, 04-06 December 2025. IEEE, pp. 48–53. Available at: <https://doi.org/10.1109/IC2SDT68218.2025.11383608>.

Linksys (2014) *Linksys N300 Wi-Fi Router E1700 product brief*. Available at: https://downloads.linksys.com/downloads/datasheet/MR19127_N300_WiFiRouter_PB_14PB009_E1700_me.pdf (Accessed: 12 May 2026).

NPSA (2026) *Video Surveillance, Access Control, Detection & Control Rooms | Building Protection | NPSA*. Available at: <https://www.npsa.gov.uk/building-protection/video-surveillance-access-control-detection-control-rooms> (Accessed: 10 May 2026).

Ogudo, K.A. (2019) ‘Analyzing generic routing encapsulation (GRE) and IP Security (IPSec) tunneling protocols for secured communication over public networks’, *icABCD 2019 - 2nd International Conference on Advances in Big Data, Computing and Data Communication Systems*, Winterton, South Africa, 05-06 August. IEEE. Available at: <https://doi.org/10.1109/ICABCD.2019.8851004>.

Kotha, N.R. (2020) ‘Network segmentation as a defense mechanism for securing enterprise networks’, *Turkish Journal of Computer and Mathematics Education (TURCOMAT)*, 11(3), pp. 3023–3030. Available at: <https://doi.org/10.61841/turcomat.v11i3.14942> (Accessed: 12 May 2026).

Parthasarathy, R., Krishnan, N.M., Perumal, I., Ayyappan, P., Rajamanickam, L. and Alias, S.B. (2021) ‘Configuration of access control list applications: route filtering and traffic control for enterprise network design using Cisco Packet Tracer simulation tool’, *Science International (Lahore)*, 33(3), pp. 265–271. Available at:

https://www.researchgate.net/publication/360088057_CONFIGURATION_OF_ACCESS_CONTROL_LIST_APPLICATIONS_ROUTE_FILTERING_AND_TRAFFIC_CONTROL_FOR_ENTERPRISE_NETWORK_DESIGN_USING_CISCO_PACKET_TRACER_SIMULATION_TOOL (Accessed: 12 May 2026).